Lecture Slides:

• SLIDE 1 - DATABASE SECURITY**

• Subtitle:* This lecture surveys the foundational principles, technical controls, and contemporary challenges of protecting relational and NoSQL data stores.

• Key themes**

• The CIA triad as a security framework for databases.

• Authentication, authorization, and access-control architectures.

• Encryption, monitoring, and compliance mechanisms in modern deployments.

•

• SLIDE 2 - LEARNING OBJECTIVES**

By the end of this lecture, students will be able to:

1. Articulate precise definitions of **confidentiality, integrity, and availability** as they apply to database systems.

2. Compare **discretionary, mandatory, and role-based access-control** models and justify the selection of each in a given scenario.

3. Design a layered protection strategy that incorporates **authentication, encryption (at rest & in transit), and audit logging**.

4. Evaluate a real-world breach case study using threat-modeling techniques such as **STRIDE** to identify mitigations.

•

• SLIDE 3 - CONTEXT & RELEVANCE**

• Databases hold the majority of mission-critical and personally identifiable information in enterprise applications.

• The concentration of high-value data makes databases a frequent target; **19 % of breaches involved database compromise (Verizon DBIR 2023)**.

• Perimeter-only defenses are insufficient-insider threats and credential theft can bypass network-level controls.

• A systematic security posture requires **preventive controls** (e.g., encryption) **and detective controls** (e.g., activity monitoring).

• Cloud-native architectures add new attack surfaces: mis-configured storage buckets, exposed management APIs, etc.

• Speaker note:* Emphasise that database security is multidimensional and extends far beyond the classic "firewall-only" mindset.

•

• SLIDE 4 - CORE CONCEPT 1: THE CIA TRIAD IN DATABASES**

• **Confidentiality** - Only subjects with appropriate credentials may read or export data; enforced via encryption, masking, and column-level controls.

• **Integrity** - Data must remain accurate and unaltered except by authorized transactions; upheld by constraints, checksums, and immutable transaction logs.

• **Availability** - The system must deliver data to legitimate users within defined performance thresholds; achieved through **replication, fail-over clusters, and rigorous backup strategies**.

• The three properties are inter-dependent; e.g., excessive encryption **without proper key-management can degrade availability** by causing latency or service-outage during key rotation.

• Quantitative metrics (RPO, RTO, false-positive rates) enable continuous improvement of the security program.

• Visual cue:* Insert a **Venn-diagram** showing overlap of CIA elements and example controls for each.

• Speaker note:* Highlight the need to balance the three pillars rather than optimise one at the expense of the others.

•

• SLIDE 5 - CORE CONCEPT 2: AUTHENTICATION & AUTHORIZATION**

• **Authentication** validates identity of users, services, or devices before any DB interaction (passwords, MFA tokens, X.509 certificates, Kerberos tickets).

• **Authorization** determines which operations (SELECT, INSERT, ALTER, ...) an authenticated principal may perform (GRANT statements, role memberships).

• **Role-Based Access Control (RBAC)** abstracts individual privileges into roles → simplifies administration & supports least-privilege.

• **Mandatory Access Control (MAC)** enforces system-wide policies based on security labels → stronger isolation for highly classified data.

• Continuous re-evaluation of session context (IP, device posture, risk score) is a core tenet of **zero-trust** database access.

• Visual cue:* Show a **flowchart** from authentication → session creation → authorization check.

• Speaker note:* Stress that strong authentication is a prerequisite for any meaningful authorization policy.

•

• SLIDE 6 - CORE CONCEPT 3: ACCESS-CONTROL MODELS & PRIVILEGE MANAGEMENT**

• **Discretionary Access Control (DAC)** - Object owners grant rights directly; can lead to privilege creep if not audited.

• **Mandatory Access Control (MAC)** - Immutable policies supersede owner discretion; reduces risk of inadvertent over-granting.

• **RBAC** - Aligns permissions with business functions, enables separation of duties (SoD), and simplifies compliance reporting.

• **Fine-grained delegation** - Grant EXECUTE on specific stored procedures rather than broad table rights → limits impact of compromised accounts.

• **Automated privilege-audit tools** detect anomalous grant patterns and recommend revocation to enforce least-privilege.

• Visual cue:* Use a **comparative matrix** (rows = DAC, MAC, RBAC; columns = owner control, policy rigidity, typical use-case).

• Speaker note:* Use a diagram to contrast DAC, MAC, and RBAC, illustrating where each model is most appropriate.

•

• SLIDE 7 - DEEP DIVE: TECHNICAL MECHANISMS**

• **Transparent Data Encryption (TDE)** - AES-256 applied to data files & backups; < 5 % performance overhead on modern hardware.

• **TLS 1.2/1.3** - Encrypts client-to-server traffic, protecting credentials & query payloads from network-level eavesdropping.

• **Database Activity Monitoring (DAM)** - Captures every DDL/DML event, correlates patterns against baselines, alerts on anomalous queries (e.g., tautological predicates).

• **Immutable auditing** - Logs stored in WORM repositories provide forensic evidence for regulatory investigations.

• **Patch management** - Timely application of vendor security advisories eliminates known exploitable vulnerabilities (e.g., CVE-2022-XXXX).

• Visual cue:* Layered "defence-in-depth" diagram with TDE, TLS, DAM, Auditing, Patch Management stacked.

• Speaker note:* Illustrate how these mechanisms form a layered defence-in-depth architecture.

•

• SLIDE 8 - REAL-WORLD APPLICATIONS & EXAMPLES**

• **2022 Capital One breach** - Mis-configured WAF allowed SQL-injection payload; underscores need for input sanitisation & DAM.

• **RBAC with strict SoD** - Reduced average breach cost by 27 % (Ponemon 2023).

• **Cloud-native encryption** - AWS RDS with TDE shows < 2 % latency increase, proving practicality at scale.

• **Homomorphic encryption prototypes** - Enable secure analytics on encrypted health records, satisfying HIPAA while preserving utility.

• **Zero-trust database gateways** - Per-query authentication blocked 94 % of lateral-movement attempts in recent red-team exercises.

• Speaker note:* Connect each example back to confidentiality, integrity, or availability controls discussed earlier.

•

• SLIDE 9 - CRITICAL THINKING & ANALYSIS**

1. **Least-privilege vs. performance** - How might strict privilege limits conflict with high-throughput OLTP workloads? Propose mitigation strategies (e.g., role-hierarchies, caching of privilege checks).

2. **Full-disk vs. column-level encryption** - Evaluate trade-offs when compliance mandates selective data protection.

3. **Signature-based DAM vs. ML-based anomaly detection** - Critically assess effectiveness for novel SQLi techniques.

4. **STRIDE for databases** - Adapt threat-modeling to enumerate DB-specific attack surfaces (e.g., privilege escalation via stored procedures).

5. **Ethics of homomorphic encryption** - Discuss implications for data ownership & accountability in outsourced analytics.

• Speaker note:* Prompt small-group debates; require evidence-based arguments and citation of at least one scholarly source per argument.

•

• SLIDE 10 - SUMMARY & DISCUSSION**

• Key take-aways**

• The **CIA triad** provides a conceptual scaffold for evaluating confidentiality, integrity, and availability in database environments.

• Robust **authentication, granular authorization, and appropriate access-control models** are essential to enforce least-privilege.

• **Encryption, activity monitoring, and disciplined patch management** constitute the technical backbone of a resilient database security program.

• Discussion question**

• In a multi-cloud architecture where data resides across heterogeneous DBMS platforms, how would you design a unified security policy that satisfies both technical constraints and diverse compliance mandates?*

• Further reading**

• NIST SP 800-53 Revision 5 - "Database Security" controls (https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final)

• Verizon Data Breach Investigations Report 2023 (Verizon 2023, *Data Breach Investigations Report*, https://www.verizon.com/business/resources/reports/dbir/)

•